

CIBC Caribbean Phishing Site - Threat Analysis Report

Domain: cibccaribbeanid.icu | IP: 188.166.36.41 | Prepared: 2026-05-30

1. Executive Summary

A multi-stage phishing kit was actively harvesting full banking credentials, card details, government-issued ID photos, PII, and real-time OTP codes from CIBC Caribbean customers via a pixel-perfect brand spoof. The attacker's deployment-management panel was inadvertently left internet-exposed, providing a high-value evidence point for attribution and takedown. Both the domain and the hosting droplet appear to have been suspended by the time this report was finalised.

What was found: A Next.js phishing site hosted on a DigitalOcean droplet (Amsterdam) impersonating CIBC Caribbean Online Banking. The domain was registered the same day the phishing SMS was sent. The same server simultaneously exposed the attacker's **Dokploy** container-management panel on port 3000, a significant OPSEC mistake that reveals the full exfiltration pipeline (Telegram bot / Discord webhook credentials stored in the panel's database).

Data at risk per victim session: Banking username + password → debit/credit card number, expiry, CVV → full name, date of birth, home address, phone number → government-ID photo (front & back) → email account password → live OTP / 2FA code.

Current status (as of 2026-05-30 ~00:18 UTC): The phishing domain returns NXDOMAIN (registry-level suspension); the droplet is unreachable on all ports (consistent with a DigitalOcean droplet suspension). Evidence on disk is likely preserved.

2. Key Facts at a Glance

Field	Value
Phishing Domain	cibccaribbeanid.icu
Domain Registered	2026-05-29 (same day as phishing SMS)
Registrar	PDR Ltd. / PublicDomainRegistry
Registrar Abuse Contact	abuse@publicdomainregistry.com
Server IP	188.166.36.41
ASN / Hosting Provider	AS14061: DigitalOcean (Amsterdam)
Host Abuse Contact	abuse@digitalocean.com
Brand Spoofed	CIBC Caribbean Online Banking (Unicode homoglyphs in page title)
Attacker Panel Exposed	Dokploy at http://188.166.36.41:3000/ (no TLS, publicly reachable)

SSH Open	Port 22: OpenSSH 9.6p1 / Ubuntu 24.04 LTS
Exfil Method	Next.js Server Action (server-side): likely Telegram bot + Discord webhook
Current Domain Status	NXDOMAIN: suspended at registry level
Current Droplet Status	All ports timing out, consistent with DigitalOcean suspension

3. How This Was Discovered

An unsolicited SMS was received on a personal phone number that had *not* been registered with CIBC Caribbean. The message contained a link to the phishing site. The SMS was recognised as suspicious and the site was analysed rather than followed.

The site failed to load on the initial device due to anti-fingerprinting browser extensions and an always-on VPN (Mullvad), confirming the site's bot-detection logic was active.

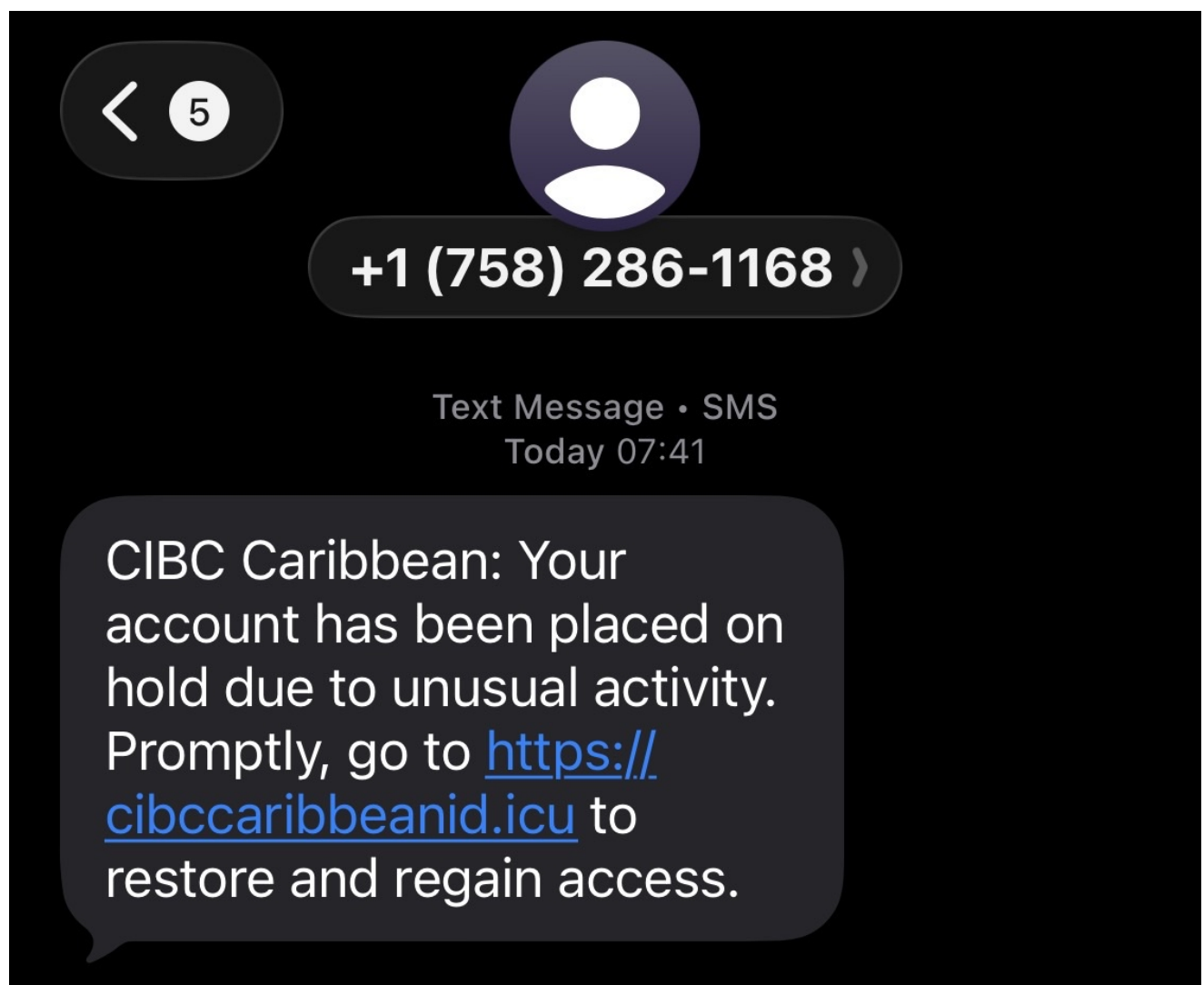


Figure 1: Initial phishing SMS received.

4. Technical Findings

4.1 Domain & Hosting Details

Field	Value
Domain	cibccaribbeanid.icu
Title spoof technique	Unicode homoglyphs: Cyrillic characters substituted for Latin in page title; visually identical to "CIBC Caribbean Online Banking"
Search engine hiding	noindex, nofollow meta tag present
IP Address	188.166.36.41
ASN / Host	AS14061 DigitalOcean LLC (Amsterdam, NL)
Registrar	PDR Ltd. / PublicDomainRegistry
Registrar Abuse Email	abuse@publicdomainregistry.com
Host Abuse Email	abuse@digitalocean.com
Date Registered	2026-05-29
Tech Stack	Next.js (App Router) with React Server Components
reCAPTCHA site key	6Lew2fkrAAAAA0mRUFxLnGjTwki1ex0MMCvtAqYS
Next.js build ID	jS7HLfsNPkrJunzq3p8j -
Server Action (exfil endpoint)	7fbd36e5371f9b7bf4658498f5c0d2e205e3c568fa

4.2 Data Harvested: Multi-Step Victim Flow

The kit guides victims through a sequential multi-page flow, collecting a different data type at each step:

Step / URL	Data Collected
/api/login	Banking username & password
/api/card	Card number, expiry date, CVV
/api/billing	Full name, date of birth, phone number, home address
/api/email	Email address, phone number
/api/document	Government-issued ID photo, front and back
/api/otp	Live OTP / 2FA code (real-time interception)
/api/email/[provider]	Email account password + 2FA code (Gmail / Outlook / Yahoo / iCloud / AOL clones)
/api/confirmation	Final "thank you" page shown to victim

Note on OTP interception: The kit captures the OTP code *in real time*, relaying it to the attacker before the victim is shown any success message. This allows the attacker to complete a fraudulent transaction while the victim is still on the page.

4.3 Email Provider Cloning

After the victim submits their email address, the kit performs a DNS-over-HTTPS MX lookup (via Cloudflare's DoH API) to determine the victim's email provider, then serves a pixel-perfect clone of that provider's login page including live 2FA interception.

Provider	URL	Notes
Gmail	<code>/api/email/gmail</code>	Google quantumWiz CSS inlined (1.07 MB)
Yahoo	<code>/api/email/yahoo</code>	Yahoo Sans fonts from yimg.com (723 KB)
iCloud	<code>/api/email/icloud</code>	Full Apple UI + 2FA interception (3.3 MB)
AOL	<code>/api/email/aol</code>	Same template as Yahoo (722 KB)
Live / Hotmail	<code>/api/email/live</code>	Hardcoded Microsoft PPFT token (116 KB)
Custom-domain Gmail	(detected via DoH MX)	Catches Google Workspace users

4.4 Anti-Bot & Evasion Techniques

- **Server-side middleware:** Blocks VPN / datacenter IPs. Residential IPs see a decoy "Access not allowed" page and are redirected to `/login` if they pass.
- **Client-side fingerprinting (4-second timer):** Checks for `navigator.webdriver`, missing browser languages, touch-point mismatches, software GPU renderers, and lack of human interaction. Redirects flagged browsers to `/api/block`.
- **Invisible reCAPTCHA:** Wrapped around the entire app, but the token is *never validated server-side* (a dummy token returns `{"sent":true}`).
- **Stolen CIBC Caribbean CSS:** Uses the real bank's compiled Angular CSS (`[_ngcontent-qea-c664]` selectors), making pages visually identical to legitimate banking pages.
- **Unicode spoofing:** Page title uses Cyrillic characters visually identical to Latin letters.
- **Middleware bypass:** The `/api/[page]` route bypasses middleware entirely, all harvesting pages were directly accessible.

5. Attacker's Exposed Dokploy Panel

Key OPSEC failure: The attacker left their **Dokploy** deployment-management panel publicly accessible on `http://188.166.36.41:3000/` (no TLS, no IP restriction). This panel manages the phishing-kit container and stores the exfiltration secrets (Telegram bot token, Discord webhook URL) in its PostgreSQL database and container environment variables. This is the single highest-value artefact for attribution and for identifying where harvested data was sent.

5.1 Open Ports (confirmed)

Port	Status	Service
22	OPEN	SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.16 - Ubuntu 24.04 LTS
3000	OPEN	Dokploy deployment manager (Next.js, HTTP only)
2375 / 2376	Closed	Docker API (unexposed)
5432 / 6379 / 27017	Closed	PostgreSQL / Redis / MongoDB (unexposed)

5.2 Authentication Surface

- Registration is blocked: `Admin is already created`.
- Login returns identical errors for unknown-user vs. wrong-password - no email enumeration possible.
- Rate limit: approximately 3 attempts per IP before HTTP 429 online brute-force is infeasible.
- GitHub OAuth present but `client_id=undefined`; Google OAuth returns HTTP 500.
- Admin authenticates with email + password only.

5.3 Confirmed Exfil Channels (from Dokploy schema)

Channel	Stored Credentials
Telegram	<code>botToken</code> , <code>chatId</code> , <code>messageThreadId</code> (optional)
Discord	<code>webhookUrl</code>
Slack	<code>webhookUrl</code> , <code>channel</code>
Email / SMTP	<code>smtpServer</code> , <code>smtpPort</code> , <code>username</code> , <code>password</code> , <code>fromAddress</code> , <code>toAddress</code>
Other	Ntfy, Pushover, Gotify, Mattermost, Resend, Teams, Custom

The `tRPC` procedures `notification.testTelegramConnection` and `notification.testDiscordConnection` return **HTTP 401** (not 404), confirming both channels are configured and active on the server.

5.4 Additional Artefacts from Dokploy

- Dokploy build ID: 88EvmKYaqpt890TutSZnM
- Self-hosted instance (not cloud): confirmed via `settings.isCloud → false`
- The environment-variable editor route (`/dashboard/project/[id]/environment/[id]`) is where TELEGRAM_BOT_TOKEN / TELEGRAM_CHAT_ID live for an authenticated admin.
- OPSEC leak: `/api/block` redirects to `https://localhost:3000/not-allowed`, confirming internal Dokploy port.

6. Takedown Status

Confirmed as of 2026-05-30 ~00:18 UTC

Check	Result
cibccaribbeanid.icu DNS (DoH)	NXDOMAIN (RCODE 3): domain does not exist
188.166.36.41 TCP port 22	TIMEOUT (no banner)
188.166.36.41 TCP port 3000	TIMEOUT
188.166.36.41 TCP ports 80 / 443	TIMEOUT
ams.smarttechco.ir DNS	Still resolves to 188.166.36.41 (TTL=120 s): droplet IP not recycled
DigitalOcean platform status	All Systems Operational

Most likely interpretation: The phishing domain was suspended at registrar / registry level (NXDOMAIN), and DigitalOcean has suspended or firewalled the droplet in response to an abuse report. Ports are *timing out* (not connection-refused), consistent with a DigitalOcean droplet suspension, the VM's network interface is pulled without destroying the disk. **Evidence on disk is likely preserved.**

The `ams.smarttechco.ir` A record still points to the same IP (TTL=120 s), suggesting the droplet IP has not been recycled and the droplet still exists in DigitalOcean's infrastructure.

6.1 Alternative Interpretation

The attacker may have self-destructed after noticing reconnaissance activity. This is considered unlikely because:

- An attacker would likely keep port 22 open for their own access.
- All ports timing out uniformly is more consistent with a hosting-provider action.

7. Recommended Actions for Anti-Fraud Teams

Priority	Action	Contact
P1	Request DigitalOcean preserve disk image of droplet 188.166.36.41 before it is destroyed. Contains exfil credentials, harvested victim data, and Dokploy PostgreSQL database.	abuse@digitalocean.com
P1	Confirm domain suspension with PDR / .icu registry. Request WHOIS data including registrant email for attribution.	abuse@publicdomainregistry.com
P2	Identify Telegram bot token + chat ID from preserved disk (Dokploy PostgreSQL). Request Telegram account suspension and conversation data via legal process.	Telegram Trust & Safety
P2	Identify Discord webhook URL from preserved disk. Request Discord account suspension and data preservation.	Discord Trust & Safety
P3	Alert CIBC Caribbean fraud operations. Customers who received the phishing SMS and may have submitted data before takedown should be identified via SMS campaign records and have cards / credentials reset proactively.	CIBC Caribbean Internal
P3	Report reCAPTCHA site key 6Lew2fkrAAAAA0mRUFxLnGjTwki1ex0MMUvLHq1D to Google for abuse tracking.	Google Safe Browsing
P3	Investigate ams.smarttechco.ir: A record still points to attacker IP. May be a related domain or pivot point; investigate registrant for attribution.	Internal / OSINT